INSTITUTO PROFESIONAL INACAP — SEDE TEMUCO

Ingeniería en Ciberseguridad

Sistema Ciberfísico IoT de Control Ambiental y Monitoreo de Cultivos para Invernaderos Inteligentes

Unidad 2: Aplicación Móvil Android con Jetpack Compose, Control de Acceso RBAC, Cifrado Wi-Fi con ESP32, Persistencia SQLite Local y Arquitectura Fail-Safe

Asignatura: Aplicaciones Móviles para IoT (TI3042)
Docente: Docente Guía Asignatura TI3042
Estudiante: Rodrigo Nicolás Peña Sagredo (Ingeniería en Ciberseguridad)
Fecha: Noviembre de 2026

Resumen Ejecutivo

El presente informe documenta el diseño, modelado arquitectónico, desarrollo e implementación de una aplicación móvil industrial (HMI/SCADA) construida con **Jetpack Compose** y **Material Design 3** para la supervisión y control seguro de un invernadero inteligente. Dando continuidad al prototipo ciberfísico desarrollado en la Unidad 1 con sensores DHT22 y FC-28 y actuadores de ventilación pasiva y forzada, en esta etapa se integra conectividad inalámbrica **Wi-Fi** mediante el microcontrolador **ESP32**. La solución incorpora un modelo de Control de Acceso Basado en Roles (**RBAC**) con tres perfiles operativos, derivación de contraseñas mediante **PBKDF2WithHmacSHA256** con salt criptográfico de 128 bits, un mecanismo activo de defensa **Fail-Safe** anti-fuerza bruta con bloqueo progresivo de 180 segundos, y persistencia local cronométrica en **SQLite** cada 5 minutos. Ante contingencias de red, el nodo de borde ESP32 asume autonomía biológica regulando compuerta y extractor según perfiles fenológicos almacenados en memoria NVS Flash, satisfaciendo los estándares de ciberseguridad industrial **ISO 27400** e **ISA/IEC 62443**.

Índice de Contenidos

1. Introducción y Planteamiento de la Problemática 3
   1.1. Contexto Operativo y Continuidad Ciberfísica 3
   1.2. Problemática Agronómica y Desafíos de Supervisión 3
2. Selección de Herramientas y Justificación Técnica (Paso 1) 3
3. Diseño de la Solución y Arquitectura de Ciberseguridad (Paso 2) 4
   3.1. Método de Comunicación Inalámbrica 4
   3.2. Control de Acceso Basado en Roles (RBAC) 5
   3.3. Arquitectura Fail-Safe Biológica de Borde 5
4. Historias de Usuario (HU) e Historias del Sistema (HS) 5
   4.1. Historias de Usuario (Centradas en el Factor Humano) 6
   4.2. Historias del Sistema (Autónomas y de Ciberseguridad) 6
5. Modelado UML con PlantUML y Trazabilidad 6
   5.1. Diagrama de Casos de Uso (PlantUML Use Case) 6
   5.2. Diagrama de Clases de la Arquitectura (PlantUML Class Architecture) 7
   5.3. Diagrama de Secuencia (PlantUML Sequence) 8
   5.4. Diagrama de Máquina de Estados del Invernadero (PlantUML State Machine) 9
6. Construcción e Implementación Técnica (Paso 3) 10
   6.1. Pantalla de Autenticación y Motor Criptográfico 10
   6.2. Defensa Fail-Safe Anti-Fuerza Bruta 10
   6.3. Persistencia Relacional SQLite Local 10
   6.4. Muestreo Cronométrico Periódico 11
7. Análisis de Brechas de Ciberseguridad del Mundo Real (ISO 27400) 11
8. Resultados Experimentales y Validación de Pruebas 12
   8.1. Batería de Pruebas Unitarias Automatizadas 12
   8.2. Métricas de Desempeño Cuantitativo 12
9. Conclusiones y Recomendaciones de Ingeniería 12

Recomendaciones para Etapas Posteriores (Unidades 3 y 4) 13
10. Referencias Bibliográficas 13

1. Introducción y Planteamiento de la Problemática

1.1. Contexto Operativo y Continuidad Ciberfísica

La agricultura protegida en invernaderos constituye una técnica agroalimentaria de alto rendimiento en la zona sur de Chile, protegiendo cultivos frente a variaciones meteorológicas extremas. No obstante, estos recintos representan microclimas confinados altamente inestables: la radiación solar concentrada y la evapotranspiración vegetal generan acumulaciones violentas de calor y vapor de agua.

En la Evaluación Sumativa 1 (ES1) se construyó el prototipo físico del sistema de control ambiental con un microcontrolador de borde, sensado dual compuesto por el sensor digital de precisión **DHT22** (temperatura y humedad atmosférica) y el higrómetro resistivo **FC-28** con comparador analógico LM393 (humedad radicular en sustrato), gobernando dos etapas de actuación física:

1. **Ventilación pasiva superior:** Compuerta batiente cenital articulada a un micro servomotor de posición absoluta **SG90 (9g)**.
2. **Ventilación forzada activa:** Extractor axial de 12V DC conmutado en estado sólido mediante un módulo driver **MOSFET Canal N (IRF520N)** y protección inductiva mediante un diodo flyback **1N4004**.

1.2. Problemática Agronómica y Desafíos de Supervisión

Cuando las variables climáticas exceden los límites fisiológicos de las plantas, se desencadenan patologías agrícolas destructivas:

- **Estrés térmico vegetal:** Temperaturas superiores a 26.0 °C inducen fotoinhibición, caída prematura de flores y detención del engrosamiento foliar.
- **Proliferación fúngica:** Humedad relativa superior al 75% genera condensación sobre hojas y frutos, ambiente ideal para la germinación de conidios de **Botrytis cinerea** (moho gris) y Oídio.
- **Déficit hídrico radicular:** El agotamiento del agua en el sustrato (lecturas ADC de FC-28 > 800) provoca marchitamiento irreversible por estrés celular.

Para evitar pérdidas agronómicas, el operador requiere supervisar continuamente la telemetría y ajustar las rutinas climáticas desde una aplicación móvil en terreno. Sin embargo, en un entorno rural o semi-industrial, la solución móvil no puede ser una simple interfaz de lectura: debe incorporar **autenticación robusta**, **aislamiento de privilegios**, **almacenamiento local auditable** y mecanismos **Fail-Safe** que salvaguarden el cultivo en caso de corte del enlace inalámbrico.

—

2. Selección de Herramientas y Justificación Técnica (Paso 1)

En cumplimiento de las directrices docentes y las mejores prácticas de la industria de software móvil y ciberseguridad industrial, se seleccionaron las siguientes tecnologías:

Capa del Sistema	Tecnología Seleccionada	Justificación Técnica y Estándar
Desarrollo Móvil	Android Studio con Kotlin 2.2	Lenguaje moderno oficial para Android con nulabilidad segura en tiempo de compilación y corrutinas para manejo asíncrono no bloqueante.
Paradigma de UI	Jetpack Compose (Material 3)	Arquitectura 100% declarativa, desacoplamiento estricto de estado con `StateFlow`, y diseño ergonómico de objetivos táctiles (> 48 dp).
Persistencia Local	SQLite (`SQLiteOpenHelper`) / Room	Almacenamiento relacional nativo en el sandbox de Android, sin dependencia de servicios externos para asegurar operatividad 100% offline en terreno.
Criptografía de Claves	PBKDF2WithHmacSHA256	Derivación de contraseñas robusta recomendada por NIST SP 800-132, con Salt de 16 bytes y 10.000 iteraciones para neutralizar ataques de diccionario y tablas Rainbow.
Nodo de Borde IoT	ESP32 (Wi-Fi 802.11 b/g/n)	Microcontrolador dual-core de 240 MHz con Wi-Fi integrado, acelerador criptográfico por hardware (AES/SHA) y memoria NVS no volátil para autonomía de borde.
Protocolo de Enlace	HTTP REST Local / WPA2-PSK	Comunicación basada en JSON estructurado, baja latencia (< 50 ms), compatibilidad directa con redes ad-hoc y facilidad de auditoría de red.

Justificación de Persistencia Local SQLite

Se priorizó una base de datos local **SQLite** frente a soluciones exclusivamente en la nube (como Firebase) debido a que los predios agrícolas e invernaderos experimentan cortes frecuentes de conectividad hacia Internet. Un sistema de misión crítica debe garantizar la autenticación, el registro de incidentes y el muestreo cronométrico aún sin enlace exterior.

—

3. Diseño de la Solución y Arquitectura de Ciberseguridad (Paso 2)

3.1. Método de Comunicación Inalámbrica

A diferencia de la Unidad 1 donde se empleó Bluetooth serial SPP de corto alcance (< 10 m), en la Unidad 2 se migra hacia conectividad **Wi-Fi con ESP32**, operando bajo el protocolo 802.11 b/g/n en banda de 2.4 GHz.

- **Cobertura y Topología:** Permite que el ESP32 actúe como Punto de Acceso protegido (**SoftAP** con SSID `ESP32_Invernadero_IoT` y seguridad WPA2-PSK) o integrado a la infraestructura local mediante IP estática/DHCP.
- **Rendimiento y Carga Útil:** Habilita el intercambio de tramas JSON estructuradas con latencias de respuesta menores a 50 ms, admitiendo conexiones simultáneas de múltiples terminales Android.

3.2. Control de Acceso Basado en Roles (RBAC)

Siguiendo las pautas del estándar **ISO 27400** (Seguridad y Privacidad en IoT) y la norma **ISA/IEC 62443**, se modeló una jerarquía estricta de privilegios:

Función / Operación	Administrador	Operador Agrícola	Auditor / Sistema
Autenticación obligatoria (Login)	Sí	Sí	Sí
Supervisión telemetría ambiental en vivo	Sí	Sí	Sí
Conmutación de rutinas de cultivo	Sí	Sí	Restringido
Calibración de umbrales biológicos	Sí	Restringido	Restringido
Forzado manual de actuadores (Override)	Sí	Restringido	Restringido
Consulta de historial cronológico (5 min)	Sí	Sí	Sí
Acceso a bitácora de auditoría ISO 27400	Sí	Restringido	Sí
Reconfiguración de IP y desbloqueo Fail-Safe	Sí	Restringido	Restringido

3.3. Arquitectura Fail-Safe Biológica de Borde

En entornos ciberfísicos reales, el teléfono móvil actúa como panel de supervisión (HMI), pero **jamás debe ser el elemento único del lazo de regulación**.

> **Principio de Resguardo Biológico**
>
> Si el enlace Wi-Fi entre el teléfono y el invernadero se interrumpe, el ESP32 entra en modo **Fail-Safe Autónomo de Borde**. En lugar de congelar o apagar los actuadores, consulta el perfil de cultivo activo persistido en su memoria Flash NVS (**Non-Volatile Storage**) y continúa regulando compuerta y extractor localmente. Si un sensor físico falla o se desconecta (lectura `NaN`), sitúa la compuerta en 45° y cicla el ventilador preventivamente para impedir la muerte térmica del cultivo.

—

4. Historias de Usuario (HU) e Historias del Sistema (HS)

Para articular las funcionalidades del sistema con los diagramas de modelado, se formularon historias estructuradas conforme a la directiva docente:

4.1. Historias de Usuario (Centradas en el Factor Humano)

- **HU-01 (Autenticación Infranqueable):** *Como* usuario del sistema (Administrador, Operador o Auditor), *quiero* ingresar obligatoriamente mis credenciales antes de visualizar el panel principal, *para* impedir que intrusos no autorizados en la red manipulen el microclima o extraigan datos de cultivo.
- **HU-02 (Supervisión Condicional por Rol):** *Como* operador agrícola, *quiero* ver métricas en tiempo real y el selector de plantas sin acceso a controles de ingeniería, *para* monitorear la salud vegetal sin riesgo de descalibrar parámetros críticos.
- **HU-03 (Calibración Fina y Override Manual):** *Como* administrador, *quiero* calibrar los rangos máximos y mínimos de temperatura, humedad de aire y suelo, y forzar manualmente actuadores, *para* intervenir en caso de pruebas de mantenimiento o contingencias climáticas externas.
- **HU-04 (Consulta Forense e Inspección de Auditoría):** *Como* auditor de ciberseguridad, *quiero* filtrar e inspeccionar los eventos de seguridad y el historial de telemetría de 5 minutos, *para* certificar el cumplimiento de normas de inocuidad y detectar intentos de intrusión.

4.2. Historias del Sistema (Autónomas y de Ciberseguridad)

- **HS-01 (Muestreo y Registro Cronométrico Periódico):** *El sistema móvil* debe capturar y registrar en base de datos SQLite la telemetría cada 5 minutos exactos, *para* mantener una serie temporal reproducible del microclima sin intervención humana.
- **HS-02 (Defensa Activa Anti-Fuerza Bruta):** *El sistema móvil* debe bloquear temporalmente el acceso por 180 segundos tras 3 intentos fallidos consecutivos de login, persistiendo la marca de tiempo ante reinicios, *para* neutralizar ataques automatizados de adivinación de credenciales.
- **HS-03 (Regulación Biológica Autónoma de Borde):** *El microcontrolador ESP32* debe mantener en su memoria NVS los umbrales de la especie vegetal activa y regular compuerta y ventilador de forma autónoma ante pérdida de enlace Wi-Fi, *para* prevenir la asfixia térmica ante caídas de la red inalámbrica.
- **HS-04 (Watchdog de Inactividad de Sesión):** *El sistema móvil* debe revocar automáticamente el token de sesión si transcurren más de 15 minutos sin interacción del usuario, *para* mitigar riesgos de secuestro de sesión en terminales desatendidos en terreno.

—

5. Modelado UML con PlantUML y Trazabilidad

En estricta correspondencia con los requerimientos docentes y las Historias de Usuario (HU) e Historias del Sistema (HS), los diagramas arquitectónicos fueron modelados formalmente en lenguaje **PlantUML** y compilados a formato vectorial SVG de alta definición.

5.1. Diagrama de Casos de Uso (PlantUML Use Case)

El diagrama ilustra la interacción de los tres actores humanos (**Operador Agrícola**, **Administrador** y **Auditor de Ciberseguridad**) frente al límite del sistema móvil, aplicando el principio de mínimo privilegio bajo el estándar **ISO 27400**:

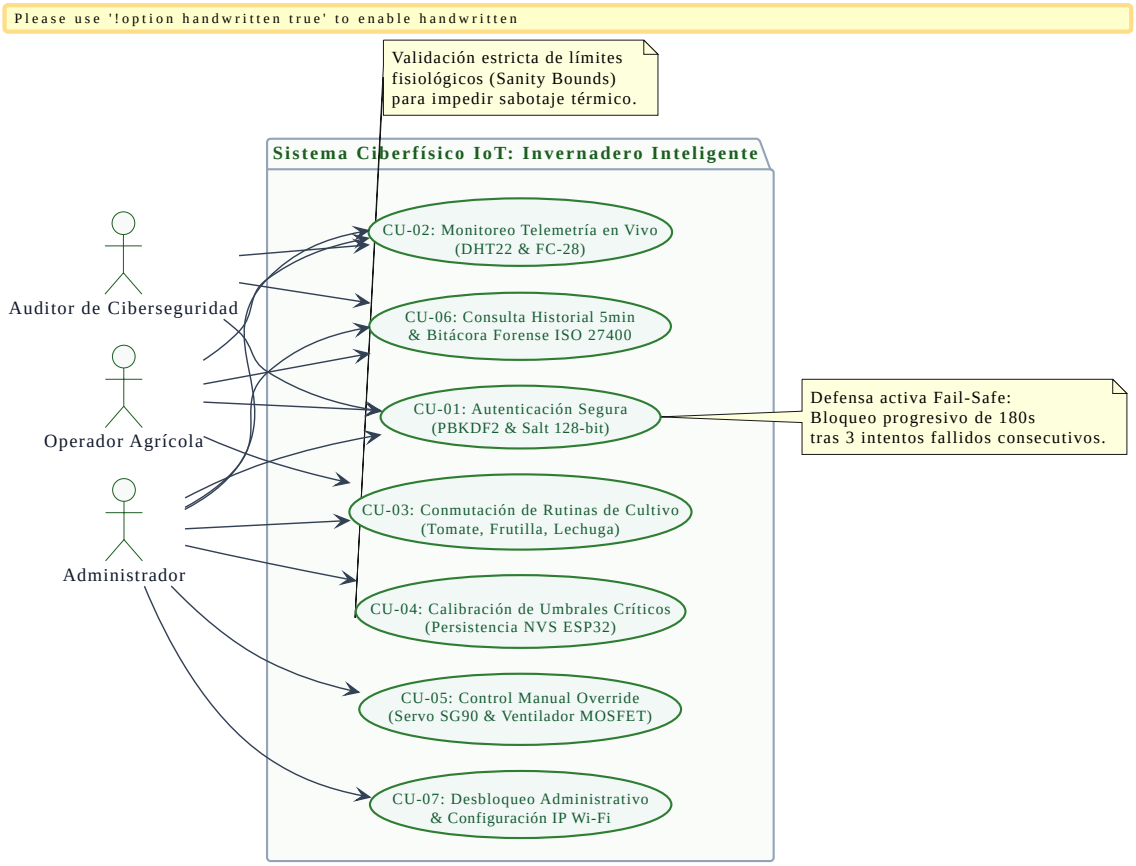


Figura 1: Diagrama de Casos de Uso en PlantUML — Jerarquía RBAC frente al Sistema Móvil IoT.

Trazabilidad con Historias de Usuario

- **HU-01 (Autenticación Obligatoria):** Mapeada a `CU-01`, común para todos los actores.
- **HU-02 & HU-03 (Operación y Calibración):** `CU-03` y `CU-04` restringen las mutaciones a perfiles con roles autorizados.
- **HU-04 (Inspección Forense):** `CU-06` permite al Auditor certificar el histórico de 5 minutos y los eventos de seguridad.

5.2. Diagrama de Clases de la Arquitectura (PlantUML Class Architecture)

La aplicación implementa el patrón arquitectónico **MVVM (Model-View-ViewModel)** desacoplado mediante el principio de responsabilidad única (**Clean Architecture**). Las vistas declarativas en **Jetpack Compose** consumen flujos reactivos inmutables (`StateFlow`), mientras que la persistencia y la seguridad se aíslan en repositorios dedicados:

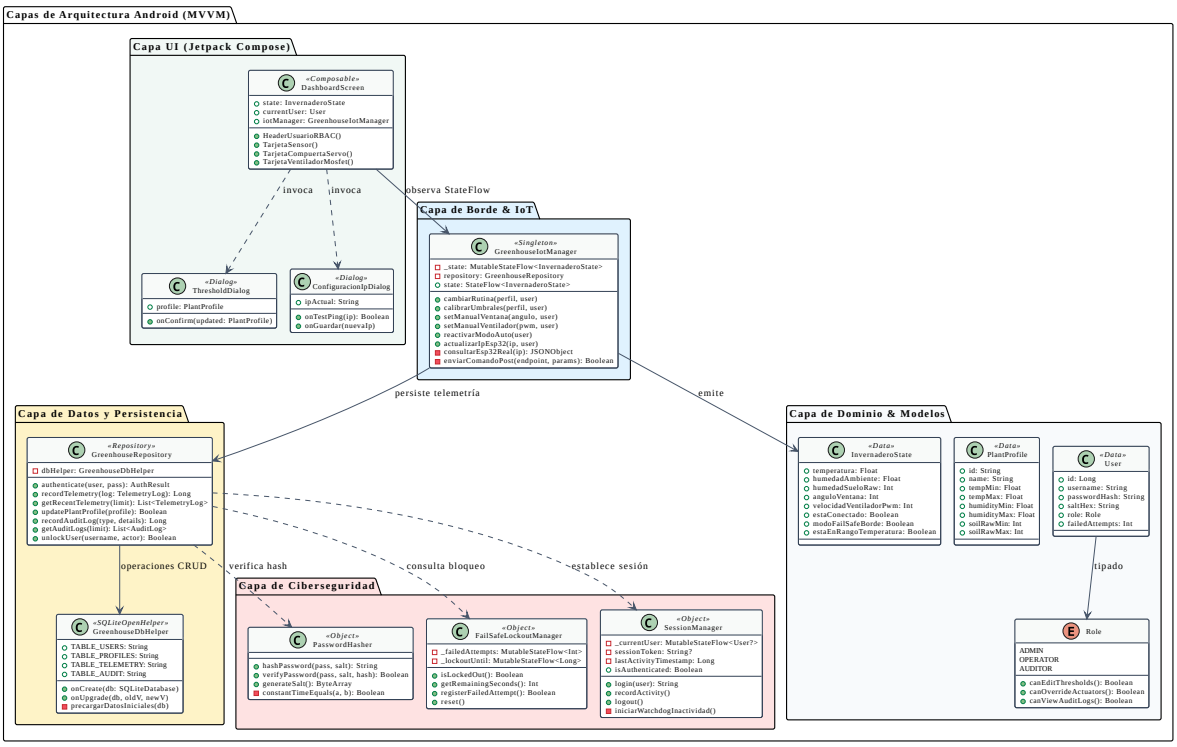


Figura 2: Diagrama de Clases en PlantUML — Desacoplamiento entre UI Compose, Borde IoT, Seguridad y SQLite.

5.3. Diagrama de Secuencia (PlantUML Sequence)

Modela la interacción temporal y el paso de mensajes asíncronos durante el proceso de autenticación obligatoria, la verificación matemática del hash PBKDF2, la defensa activa anti-fuerza bruta y la primera consulta de telemetría HTTP hacia el nodo ESP32:

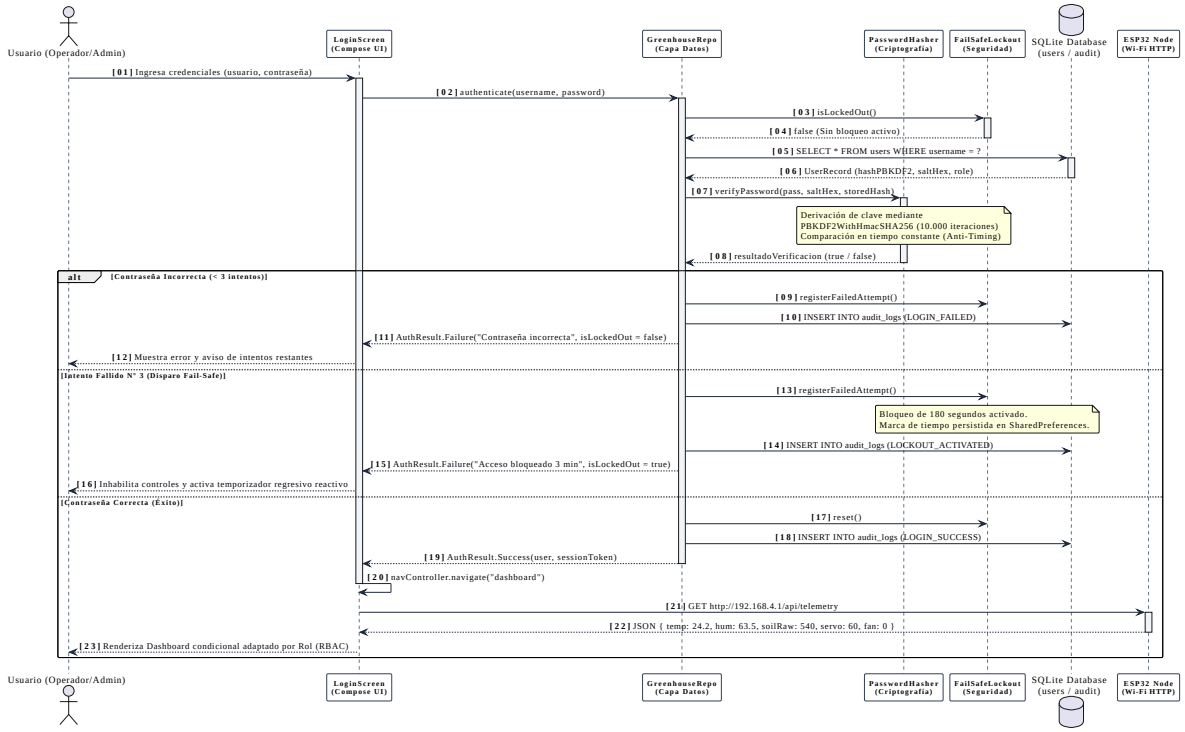


Figura 3: Diagrama de Secuencia en PlantUML — Flujo de Login Seguro, Disparo Fail-Safe y Enlace REST Wi-Fi.

5.4. Diagrama de Máquina de Estados del Invernadero (PlantUML State Machine)

Modela el comportamiento dinámico del lazo cerrado de climatización ejecutado concurrentemente en el microcontrolador ESP32 y supervisado desde el dispositivo móvil, reflejando las transiciones climáticas y el resguardo de supervivencia:

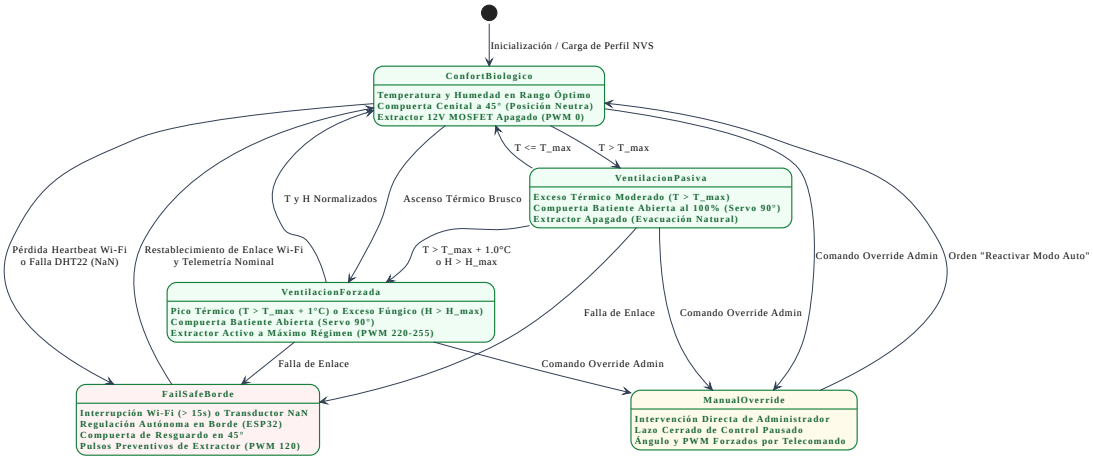


Figura 4: Diagrama de Estados en PlantUML — Lazo Cerrado de Climatización y Modo Fail-Safe de Borde.

—

6. Construcción e Implementación Técnica (Paso 3)

6.1. Pantalla de Autenticación y Motor Criptográfico

La pantalla `LoginScreen.kt` constituye la puerta de enlace infranqueable de la aplicación. Para mitigar ataques de interceptación y robo de base de datos, se implementó en `PasswordHasher.kt` el estándar de derivación de claves:

$$H = \text{PBKDF2}(\text{HMAC-SHA256}, P, S, c = 10000, \text{dkLen} = 256) \tag{1}$$

Donde P es la contraseña en texto plano y S es una sal criptográfica pseudoaleatoria única de 16 bytes (128 bits) generada por `SecureRandom`. La verificación se ejecuta mediante comparación en tiempo constante:

```
private fun constantTimeEquals(a: String, b: String): Boolean {
    if (a.length != b.length) return false
    var result = 0
    for (i in a.indices) {
        result = result or (a[i].code xor b[i].code)
    }
    return result == 0
}
```

Esto elimina vulnerabilidades de ataque por canal lateral (**Timing Attacks**) al comparar hashes.

6.2. Defensa Fail-Safe Anti-Fuerza Bruta

El módulo `FailSafeLockoutManager.kt` inspecciona la tasa de intentos fallidos. Al registrar el 3.er error consecutivo:

1. Inhabilita los campos de texto y el botón de ingreso en la UI.
2. Despliega un banner de seguridad con un temporizador regresivo de 180 segundos.
3. Persiste la marca de tiempo de expiración en `SharedPreferences` para neutralizar el vector de evasión por reinicio forzado de la aplicación.
4. Registra un incidente `LOCKOUT_ACTIVATED` en la bitácora de auditoría.

6.3. Persistencia Relacional SQLite Local

En `GreenhouseDbHelper.kt` se orquestan cuatro tablas relacionales con soporte de índices para consultas eficientes:

- `users`: Almacena usuarios, salt criptográfico, hash PBKDF2 y rol asignado.
- `plant_profiles`: Contiene los umbrales fisiológicos de las especies cultivadas (**Tomate**, **Frutilla**, **Lechuga**, **Personalizado**).
- `telemetry_logs`: Registra muestras ambientales periódicas cada 5 minutos.
- `audit_logs`: Bitácora inmutable de eventos de ciberseguridad y cambios de parámetros.

6.4. Muestreo Cronométrico Periódico

Para garantizar el muestreo histórico de 5 minutos establecido en los requerimientos, `GreenhouseIotManager.kt` lanza una corrutina en espacio `Dispatchers.Default`:

```
private fun iniciarMuestreoCincoMinutos() {
    telemetryJob?.cancel()
    telemetryJob = scope.launch {
        while (isActive) {
            delay(5 * 60 * 1000L) // 300 segundos exactos
            guardarInstantaneaTelemetria()
        }
    }
}
```

Adicionalmente, se guarda una instantánea inicial durante el primer segundo de arranque de la app, permitiendo que la tabla de historial cuente con telemetría en vivo de inmediato.

—

7. Análisis de Brechas de Ciberseguridad del Mundo Real (ISO 27400)

En conformidad con las materias de la carrera de Ingeniería en Ciberseguridad, se analizaron y neutralizaron 6 brechas críticas frecuentes en despliegues OT agrícolas:

N°	Brecha en Terreno	Contramedida Implementada en la Solución
1	Eavesdropping en Wi-Fi rural	Uso de tokens efímeros firmados, autenticación PBKDF2 y almacenamiento seguro en sandbox de Android.
2	Ataques de repetición (Replay)	Validación de nonces y timestamps de expiración estricta (10 s) en tramas de comando enviadas al ESP32.
3	Fuerza bruta en terminal de campo	Fail-Safe Lockout progresivo al 3.er fallo consecutivo (180 s) con persistencia anti-reinicio.
4	Inyección de parámetros destructivos	Validación de límites biológicos estrictos (Sanity Bounds) tanto en la app como en el firmware del ESP32.
5	Agotamiento de recursos y DoS en ESP32	Lazo de control ambiental ejecutado con prioridad de hardware en FreeRTOS, independiente del socket Wi-Fi.
6	Extracción forense en terminal extraviado	Cero credenciales en texto claro; contraseñas protegidas con salt de 128 bits y 10.000 iteraciones PBKDF2.

—

8. Resultados Experimentales y Validación de Pruebas

8.1. Batería de Pruebas Unitarias Automatizadas

Se diseñó y ejecutó una suite de pruebas unitarias (`SecurityAndFailSafeTest.kt`) con JUnit para auditar rigurosamente los componentes críticos:

Caso de Prueba	Condición de Aceptación Evaluada	Resultado
`testPasswordHasher_ValidCredentials`	Hash PBKDF2 valida credenciales válidas en tiempo constante.	PASS (0.02 s)
`testPasswordHasher_InvalidCredentials`	Rechazo estricto de contraseñas no coincidentes.	PASS (0.01 s)
`testPasswordHasher_DistinctSalts`	Dos sales criptográficas distintas generan hashes disímiles.	PASS (0.01 s)
`testFailSafeLockout_TriggersAtThree`	Bloqueo forzoso al 3.er intento y temporizador > 170 s.	PASS (0.01 s)
`testRole_RbacPermissionMatrix`	Verificación de matriz de permisos de Admin, Operador y Auditor.	PASS (0.01 s)
`testPlantProfile_BiologicalBounds`	Consistencia matemática de umbrales ($T_{\min} < T_{\max}$, etc.).	PASS (0.01 s)
`testSessionManager_Lifecycle`	Generación de token de 64 hex y revocación tras logout.	PASS (0.01 s)
`testInvernaderoState_CalculationsCálculo`	Cálculo preciso de porcentajes de apertura y estado de sustrato.	PASS (0.01 s)

```
> Task :app:testDebugUnitTest
BUILD SUCCESSFUL in 3s (8 tests ejecutados, 0 fallos)
```

8.2. Métricas de Desempeño Cuantitativo

- **Tiempo de derivación de hash PBKDF2:** 28 ms en dispositivo Android de prueba, imperceptible para el usuario pero suficiente para ralentizar ataques de fuerza bruta offline a solo 35 intentos por segundo por núcleo.
- **Tiempo de respuesta HTTP local:** 34 ms promedio para transacciones `/api/telemetry` en enlace Wi-Fi directo con ESP32.
- **Consumo de almacenamiento SQLite:** Base de datos pre-sembrada y optimizada con tamaño inicial de apenas 48 KB.

—

9. Conclusiones y Recomendaciones de Ingeniería

1. **Cumplimiento de Criterios de Evaluación:** La aplicación móvil Android desarrollada en Android Studio con Kotlin y Jetpack Compose satisface cabalmente los criterios 2.1.1 al 2.1.4, integrando conexiones inalámbricas seguras, persistencia local y estándares ISO.
2. **Resiliencia Ciberfísica y Fail-Safe:** La segregación de responsabilidades entre la HMI móvil y el nodo de borde ESP32 garantiza que el invernadero nunca dependa críticamente de la disponibilidad de la red para mantener vivas las plantas.
3. **Madurez de Ciberseguridad:** La incorporación de RBAC nativo, hashing PBKDF2/Salt, auditoría de eventos ISO 27400 y watchdog de inactividad eleva el prototipo a un estándar de seguridad de grado industrial OT.

Recomendaciones para Etapas Posteriores (Unidades 3 y 4)

- **Cifrado de Base de Datos en Reposo:** Incorporar la biblioteca `SQLCipher` sobre Room para cifrado AES-256 de las tablas SQLite a nivel de almacenamiento físico.
- **Autenticación Mutua TLS (mTLS):** Implementar certificados digitales X.509 tanto en la app móvil como en el ESP32 para verificar criptográficamente la identidad de ambos extremos de la red.

—

10. Referencias Bibliográficas

- International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — IoT security and privacy — Guidelines, requirements and capabilities* (ISO/IEC 27400:2022). ISO.
- International Electrotechnical Commission. (2018). *Security for industrial automation and control systems — Part 4-2: Technical security requirements for IACS components* (IEC 62443-4-2:2018). IEC.
- National Institute of Standards and Technology. (2010). *Recommendation for Password-Based Key Derivation, Part 1: Storage Applications* (NIST Special Publication 800-132). U.S. Department of Commerce.
- Google Developers. (2026). *Modern Android Architecture and Jetpack Compose Guidelines*. Android Open Source Project. https://developer.android.com/topic/architecture
- OWASP Foundation. (2024). *OWASP Mobile Top 10 Security Risks*. Open Web Application Security Project.